گزارش کمبودهای قرارداد بک اند ماکان اپ

تطبیق Swagger *با بازطراحی و کلاس فوق برنامه*

MakanApp API

نسخه ۱٫۰ | ۲ نوامبر ۲۰۲۶

نتیجه اصلی

قرارداد فعلی، پایه گسترده‌ای برای آموزشگاه، پیام‌رسان، ارزیابی، منابع، دستیار و مدیریت پلتفرم دارد. کمبود اصلی نسبت به بازطراحی، تبدیل مدل ساده کلاس شخصی به کلاس مستقل با درخواست و تأیید، نقش‌های محلی، دو مسیر عضویت و گروه و کانال وابسته است.

دامنه بررسی	مقدار ثبت‌شده
مسیرهای HTTP	۳۴۲ مسیر
عملیات مستند	۳۸۸ عملیات؛ ۳۲۳ کاربری و ۶۵ ادمین
مدل‌های داده	Schema ۶۵۱
گروه‌های عملیاتی	Tag ۶۸ در عملیات
ثبت کمبودها	۲۲ مورد؛ ۶ مورد P0، ۱۲ مورد P1 و ۴ مورد P2

اولویت عملی

ابتدا چرخه تشکیل و مجوز کلاس مستقل، عضویت و اتصال پیام‌رسان کامل شود. هم‌زمان، قرارداد احراز هویت، خطاها، اعتبارسنجی و تکرار فرمان‌ها یکدست شود. امکانات آموزشی کامل و توسعه استودیو پس از تصمیم دامنه دنبال شوند.

این ارزیابی از فایل OpenAPI منتشرشده و سند محصول قبلی انجام شده است. APIهای کسب‌وکار فراخوانی، داده‌ای تغییر، کدی بررسی یا آزمون اجرا نشده است. نبود یک قرارداد در Swagger، نبود قطعی پیاده‌سازی در سرور را ثابت نمی‌کند.

راهنمای گزارش و سطح قطعیت

مبنای نیاز، سند فارسی محصول و معماری تجربه کاربری ماکان‌اپ نسخه ۱٫۰ است؛ به‌ویژه تصمیم‌های D01 تا D11 درباره کلاس مستقل. مرجع موجودی، فایل OpenAPI 3.0.1 با عنوان MakanApp.Api | v1 و نسخه 1.0.0 است.

بخش	صفحه
موجودی قرارداد و پوشش قابلیت‌های فعلی	۳ تا ۴
ثبت اولویت‌دار کمبودها	۵ تا ۷
چرخه تشکیل نقش‌ها و عضویت	۸ تا ۱۰
گروه و کانال و هماهنگی دسترسی	۱۱
احراز هویت خطا و کیفیت قرارداد	۱۲ تا ۱۴
آموزش منابع دستیار و اشتراک	۱۵ تا ۱۶
رویداد ممیزی و حریم خصوصی	۱۷
مدل قرارداد هدف و برنامه اصلاح	۱۸ تا ۱۹
معیار پذیرش و بررسی اجرای واقعی	۲۰ تا ۲۱
شواهد دقیق عملیات و مدل‌ها	۲۲ تا ۲۳
منابع و تصمیم تحویل	۲۴

معنای نتیجه‌ها

«وجود در قرارداد» یعنی مسیر یا مدل در فایل دریافت‌شده ثبت شده است. «شکاف قرارداد» یعنی داده یا رفتار لازم در همان فایل تعریف نشده یا ناقص است. «ابهام» یعنی از اسم یا شکل DTO نمی‌توان سیاست واقعی را نتیجه گرفت. «نیازمند بررسی اجرا» به مجوز، تراکنش، هم‌زمانی، فعال‌بودن سرویس یا زیرساخت اشاره دارد.

معنای اولویت

P0 پیش‌نیاز ارائه هسته فوق‌برنامه مطابق تصمیم‌های قطعی است. P1 پیش از اتصال قابل اتکای کلاینت یا عرضه عمومی دامنه مربوط تکمیل شود. P2 به تصویب قابلیت پیشنهادی یا مدل تجاری وابسته است. اولویت، برنامه انجام کار است و معادل اعلام آسیب‌پذیری امنیتی اثبات‌شده نیست.

ارجاع‌های E01 تا E20 به عملیات و Schemaهای واقعی همین snapshot اشاره می‌کنند. مسیرهای پیشنهادی در صفحه ۱۸ با برچسب پیشنهاد مشخص شده‌اند. «required» همراه «nullable» به معنی حضور الزامی فیلد با امکان مقدار null است؛ این ترکیب به‌خودی‌خود خطا نیست.

موجودی و کیفیت مستندات منتشرشده

شمارش از کل paths و components/schemas انجام شد. هر ترکیب روش HTTP و مسیر یک عملیات شمرده شده است؛ تعداد Tagها بر اساس Tagهای مورد استفاده در عملیات است .[E18]

شاخص	نتیجه	برداشت صحیح
روش‌های HTTP	۱۷۲ GET؛ ۱۵۷ POST؛ ۱۸ PATCH؛ ۲۳ DELETE؛ ۱۸ PUT	جمع ۳۸۸ عملیات؛ تعداد زیاد مسیر، کامل‌بودن هر جریان را ثابت نمی‌کند.
احراز هویت در OpenAPI	بدون securitySchemes؛ بدون security سراسری یا عملیاتی	شکاف مستندسازی؛ اثبات آزادبودن APIها نیست.
operationId	۰ از ۳۸۸	برای SDK و ردیابی عملیات شناسه پایدار پیشنهاد می‌شود.
summary و description	به‌ترتیب ۵ و ۲۰ عملیات	بخش عمده مصرف API به تفسیر نام مسیر و مدل وابسته است.
پاسخ غیر 2xx	۴۱ عملیات دارای حداقل یک پاسخ؛ ۳۴۷ فاقد آن	پاسخ خطای اجرای واقعی ممکن است وجود داشته باشد ولی در قرارداد نیامده باشد.
فقط پاسخ 200	۳۰۶ عملیات	200 به‌تنهایی اشکال نیست؛ سناریوهای خطا و حالت‌های ویژه باید روشن شوند.
محدودیت Schema	بدون minLength، maxLength، minimum، maximum، minItems، maxItems و pattern	اعتبارسنجی ممکن است در کد باشد؛ ابزار مصرف‌کننده از این سند حدود را نمی‌فهمد.
ارجاع‌های داخلی	۲۳۴۲ محل $ref؛ مورد حل‌نشدنی یافت نشد	فقط سلامت ارجاع‌های داخلی بررسی شد؛ اعتبارسنجی کامل استاندارد یا رفتار سرور نیست.

بخش‌های مستندتر

درس و جزوه، فهرست معلمان و یادگیرندگان، دعوت والد، دانلود فایل و بعضی مسیرهای پیام‌رسان توضیح دقیق‌تری دارند. برای نمونه، مسیر درس کنترل نسخه و تکرار فرمان و مجوز سازمانی را توضیح می‌دهد؛ دانلود فایل پاسخ باینری و Range و بررسی مجوز جاری را مشخص می‌کند [E09]، .[E12]

نمونه‌های JSON در قرارداد وجود دارند؛ مشکل، نبود کامل مثال نیست. بعضی مثال‌ها در چند نوع محتوا تکرار شده‌اند و نباید تعداد آنها را تعداد سناریوهای مستقل فرض کرد.

پوشش فعلی و قابلیت‌های قابل استفاده مجدد

حوزه	شاهد موجود	نتیجه برای تیم
ورود و حساب	OTP، refresh، نشست‌ها، پروفایل و Workspaces [E08]، [E14]	هویت مرکزی و حساب شخصی از صفر طراحی نشوند؛ مجوزهای مستقل تکمیل شوند.
آموزشگاه	کلاس، جلسه، حضور، درس، تکلیف، آزمون، ارزیابی و گزارش [E09]	زیرساخت آموزشی سازمانی گسترده است؛ کلاس مستقل نیازمند تعیین scope است.
کلاس شخصی	۹ عملیات ایجاد، فهرست، جزئیات، بایگانی، دعوت، پذیرش و اعضا [E01] تا [E04]	پایه‌ای برای توسعه وجود دارد؛ مدل کامل فوق‌برنامه در قرارداد دیده نمی‌شود.
پیام‌رسان	گروه، کانال، دعوت، درخواست عضویت، انتقال مالکیت و قابلیت مؤثر [E05]، [SB1]	مکانیزم‌های موجود قابل بررسی برای اتصال به کلاس‌اند.
گروه و کانال رسمی	OfficialSpacesPairResult با group و channel و وضعیت آماده‌سازی [E05]	الگوی جفت فضا موجود است؛ وابستگی اجباری سازمانی برای مستقل حل شود.
منابع و دستیار	فایل و منبع، آمادگی AI، preflight، چت و عملیات نقش‌محور [E10] تا [E12]	نبود API دستیار یا پردازش منبع ادعا نشود؛ آمادگی اجرا نیازمند شاهد جداست.
تجارت	کاتالوگ، سهمیه، quote، سفارش، پرداخت و PersonalClass در پیش‌بررسی AI [E13]	مدل تجاری مستقل را روشن کنید؛ وجود Enum به معنی تکمیل خرید کلاس نیست.
مالک و ادمین	۶۵ عملیات ادمین شامل IAM، سازمان، کاربران، ممیزی و عملیات [E06]، [E07]، [E19]	افزودن صف بررسی کلاس، توسعه این دامنه است؛ ایجاد پنل API از صفر لازم نیست.

مرز نتیجه‌گیری

ص ۲ و ۳۸۷ اطلس، پنل مالک را خارج از اطلس معرفی کرده بودند. Swagger اکنون وجود قراردادهای ادمین را نشان می‌دهد؛ این دو گزاره تعارض ندارند. همچنین وجود endpointهای AI در Swagger، فعال‌بودن مدل، OCR یا بازیابی در محیط اجرا را ثابت نمی‌کند.

ناوبری پنج‌مقصدی عمدتاً تصمیم کلاینت است؛ الزاماً به پنج API جدید نیاز ندارد. WorkspaceType فعلی با Personal و Organization نیز به‌تنهایی مشکل نیست؛ کلاس مستقل می‌تواند در فضای شخصی با شناسه و مجوز خودش اداره شود.

کمبودهای مسدودکننده هسته فوق برنامه

موارد P0، فاصله قرارداد فعلی با تصمیم‌های قطعی کلاس مستقل‌اند. در هر مورد، ابتدا امکان تکمیل مدل فعلی PersonalClasses بررسی شود. شماره G برای برنامه کار و شماره E برای شاهد است.

کد	کمبود قراردادی	اقدام ضروری و شاهد
G01	درخواست و بررسی تشکیل کلاس	مدل درخواست، نسخه، ارسال، اصلاح، رد، تأیید و رسید؛ مسیر ایجاد قبلی نیز تابع تأیید شود [E01]، E02، .[E06]
G02	مدیر نهایی و مدرس اختیاری	نقش محلی، انتساب مدیر توسط Owner/Admin، مدرس اختیاری، انتقال و تداوم مدیریت تعریف شود [E03]، .[E04]
G03	دعوت و درخواست عضویت	دعوت کامل با رد و لغو و انقضا؛ درخواست پیوستن و بررسی مدیر؛ خروج عضو؛ یک عضویت نهایی [E02]، .[E04]
G04	جفت فضای مستقل	پیوند classId با دقیقاً یک گروه و یک کانال، بدون ایجاد Organization و با metadata مناسب .[E05]
G05	هماهنگی و بازیابی	وضعیت آماده‌سازی، تلاش مجدد بدون فضای مضاعف، لغو دسترسی و ترمیم ناسازگاری مستند و آزموده شود [E01]، E03، .[E05]
G06	فعالیت و ظرفیت و بایگانی	چرخه حالت‌ها، ظرفیت و پذیرش هم‌زمان، تعلیق و بایگانی هماهنگ و سوابق تعریف شوند [E01]، .[E03]

قابلیت موجود چه مقدار از نیاز را پوشش می‌دهد

CreatePersonalClassCommand فقط title و clientOperationId می‌گیرد و PersonalClassDto برمی‌گرداند. این مدل، فرم درخواست کامل و رسید بررسی نیست. PersonalClassDto با hostUserId و isHost مدیریت ساده را نشان می‌دهد؛ قرارداد تعیین مدیر نهایی، مدرس و قابلیت‌های چندنقشی در آن دیده نمی‌شود.

معیار خروج مشترک

کاربر فعال از هر نوع حساب درخواست بدهد؛ تشکیل فقط پس از تصمیم مجاز انجام شود؛ مدرس خالی پذیرفته شود؛ دو مسیر عضویت به یک رابطه محلی برسند؛ یک گروه و یک کانال با مجوز هماهنگ ایجاد شوند. تکرار فرمان یا خطای یکی از فضاها نباید کلاس یا فضای ارتباطی مضاعف بسازد.

G05 شامل رفتارهایی است که از Swagger قابل اثبات نیستند. گزارش نمی‌گوید تراکنش یا Outbox در کد وجود ندارد؛ خواسته، قرارداد روشن و شاهد آزمون اجرای این تضمین‌هاست.

کمبودهای اتصال قابل اتکای کلاینت

موارد P1 پیش از اتصال نهایی کلاینت و عرضه عمومی دامنه مربوط تعیین تکلیف شوند. بخشی تغییر مستندات است و بخشی به قرارداد جدید کلاس و آزمون اجرا وابسته است.

کد	موضوع	کار مورد انتظار
G07	همه انواع حساب	قید حساب فعال، استقلال از نقش Student و سناریوی حساب عادی صریح شود [E01]، E04، .[E08]
G08	احراز هویت مستند	scheme واقعی احراز هویت و security هر دامنه، از جمله ادمین و مسیرهای عمومی ورود، تعریف شود [E14]، .[E18]
G09	خطای قابل پردازش	پاسخ‌های مجوز، اعتبارسنجی، تعارض، ظرفیت و نرخ؛ code، correlationId و خطای فیلد نوع‌دار شوند .[E16]
G10	حدود ورودی	طول و دامنه و تعداد، قواعد شرطی و فایل الزامی با رفتار واقعی سرویس همسان شوند [E01]، E09، .[E12]
G11	مصرف و تولید SDK	operationId پایدار، شرح نقش و زمینه و مثال مسیر موفق و خطا اضافه شود .[E18]
G12	Retry و نسخه	تکرار همان intent، تفاوت payload، نسخه کهنه و نتیجه نامعلوم برای عملیات حساس مشخص شود [E01]، E09، .[E11]
G13	پنج پاسخ فاقد نوع	نوع بدنه و Content-Type یا پاسخ بدون بدنه مناسب برای پنج عملیات روشن شود .[E18]
G14	فهرست‌های کلاس	صفحه‌بندی، فیلتر، ترتیب پایدار و محدودیت اندازه برای کلاس، اعضا و دعوت‌ها تعریف شود [E02]، .[E17]
G15	نشانی محیط امن	base URL رسمی محیط تست و عملیاتی و شیوه مصرف توکن روی HTTPS مشخص شود .[SB1]
G20	رویدادهای کلاس	کلیدهای invalidation و نسخه و ترتیب رویدادهای درخواست، عضویت و مدیریت تعریف شود .[E15]
G21	تاریخچه مجاز کلاس	دریافت سابقه با کنترل دسترسی مدیر و عضو، و تفکیک یادداشت ناظر از متن کاربر .[E19]
G22	حریم و سن و والد	اثر مسدودی، صلاحیت ارتباط، رضایت، رابطه والد و خروج از کلاس بر داده مشخص شود .[E20]

وجود security در Swagger اختیاریِ شکلی است؛ این مورد برای قابلیت مصرف قرارداد و توضیح مدل امنیت محصول ضروری پیشنهاد شده است. نبود این metadata، اثبات نبود کنترل دسترسی در سرور نیست.

توسعه‌های مشروط و مواردی که کمبود محسوب نمی‌شوند

کد	دامنه مشروط	تصمیم پیش از توسعه
G16	جلسه، درس، تکلیف، آزمون و گزارش در کلاس مستقل	تصویب دامنه آموزشی و مجوز مدرس و عضو محلی؛ مدل سازمانی موجود را بدون تطبیق استفاده نکنید .[E09]
G17	منبع و فایل کلاس مستقل	اگر منابع کلاسی فعال می‌شوند، معنای Class و اتصال فایل و مجوز مقصد تعیین شود [E10]، .[E12]
G18	استودیوی مطالعه و تاریخچه دستیار	نوع خروجی و چرخه تولید، ذخیره و تاریخچه پس از تأیید محصول مشخص شود .[E11]
G19	خرید و سهمیه مخصوص فوق‌برنامه	مالک قرارداد، پرداخت‌کننده و سهمیه شخصی یا کلاسی تعیین شود؛ PersonalClass در پیش‌بررسی موجود است .[E13]

APIهای موجود را دوباره نسازید

احراز هویت، نشست‌ها، گروه و کانال، دعوت و درخواست عضویت پیام‌رسان، انتقال مالکیت گفتگو، ممیزی ادمین، گزارش، منابع، چت AI و پیش‌بررسی سهمیه قرارداد دارند. فاصله جدید معمولاً در اتصال این قابلیت‌ها به کلاس مستقل و توضیح قواعد آن است، نه نبود همه زیرساخت‌ها.

تعداد مقصد با تعداد سرویس یکی نیست

ناوبری پنج‌بخشی نیازمند پنج کنترلر یا سرویس جدا نیست. داشتن فقط Personal و Organization در WorkspaceType نیز اجبار به افزودن Workspace سوم ایجاد نمی‌کند. شرط اصلی، مجوز و شناسه مستقل کلاس و نساختن عضویت سازمانی ناخواسته است.

قالب مشترک را با قاعده غلط عوض نکنید

همه پاسخ‌های ایجاد الزاماً نباید 201 باشند؛ نتیجه 200 برای بازپخش یا پاسخ یک فرمان می‌تواند مناسب باشد. required و nullable با هم مجازند. نام studentUserId به‌تنهایی ثابت نمی‌کند کاربر عادی ممنوع است. این موارد باید از سیاست واقعی و قرارداد قابل مصرف نتیجه‌گیری شوند.

قابلیت آموزشی کامل برای فوق‌برنامه در گفت‌وگوی قبلی قطعی نشده است. P2ها نباید به‌صورت کمبود تعهدشده نسخه هسته یا خرابی فعلی Backend معرفی شوند.

چرخه تشکیل و وضعیت کلاس

G01 درخواست تشکیل و تصمیم پلتفرم

در کل مسیرهای snapshot، قرارداد مشخصی برای درخواست تشکیل کلاس فوق‌برنامه، صف بررسی آن و تصمیم Owner/Admin دیده نشد. POST /api/v1/personal-classes با CreatePersonalClassCommand و خروجی PersonalClassDto، قرارداد ایجاد ساده است؛ توضیحی درباره مرحله بررسی در آن ثبت نشده [E01، E02].

قرارداد هدف باید درخواست را از کلاس جدا کند: پیش‌نویس، ارسال، بررسی، نیاز به اصلاح، تأیید، رد و لغو؛ همراه با شناسه پایدار، نسخه، دلایل قابل نمایش و یادداشت داخلی جدا. مدیر پیش‌فرض درخواست‌دهنده باشد و ناظر بتواند مدیر نهایی دیگری تعیین کند. شناسه کلاس و عملیات آماده‌سازی تنها پس از تصمیم معتبر ارائه شوند.

G06 فعالیت ظرفیت و بایگانی

در PersonalClassDto فقط archived برای پایان فعالیت دیده می‌شود؛ فیلد ظرفیت یا وضعیت آماده‌سازی و تعلیق وجود ندارد. educationalWorkflowStatus نیز رشته آزاد است. بایگانی endpoint دارد اما reason، expectedVersion و اثر آن بر فضاهای ارتباطی در ورودی یا توضیح مشخص نشده است .[E03]

وضعیت‌های هدف می‌توانند آماده‌سازی، آماده تنظیم، فعال، خطای آماده‌سازی، تعلیق و بایگانی باشند؛ نام دقیق آنها تصمیم فنی است. ظرفیت باید هنگام پذیرش نهایی و به‌صورت اتمی کنترل شود. بایگانی، پذیرش و نوشتن را در هر دو فضا ببندد و سوابق مجاز را حفظ کند.

کدام API موجود جای این چرخه را نمی‌گیرد

POST /api/admin/v1/provisioning ورودی ProvisionOrganizationCommand با organizationName و مدیر اولیه سازمان دارد. این عملیات برای ساخت Organization است و نباید برای هر کلاس مستقل آموزشگاه بسازد. صف جدید کلاس می‌تواند از الگوی عملیاتی موجود الهام بگیرد ولی باید موجودیت و مرز مستقل داشته باشد .[E06]

پذیرش کار: ارسال و تأیید هم‌زمان یا چندباره یک نتیجه نهایی معتبر داشته باشد؛ مسیر قدیمی ایجاد مستقیم هم نتواند مرحله تأیید را دور بزند. رد یا اصلاح، دلیل و نسخه قابل پیگیری داشته باشد.

مدیر مدرس و صلاحیت حساب

G02 نقش محلی کلاس

PersonalClassDto دارای hostUserId و isHost است و PersonalClassParticipantDto شناسه عضو، studentUserId، active و زمان پیوستن را نشان می‌دهد. در این دامنه، قرارداد انتساب مدرس، تغییر مدیر نهایی توسط ناظر، انتقال مدیریت یا مجوزهای مستقل مدرس ثبت نشده است [E03]، .[E04]

مدل هدف باید نقش مدیر، مدرس و عضو آموزشی را در همان کلاس تعریف کند و امکان جمع نقش‌ها را داشته باشد. مدرس اختیاری باشد و نبود آن مانع راه‌اندازی هسته نشود. نقش Teacher یا Manager سازمانی نباید خودکار اختیار کلاس مستقل دیگری را بدهد. تعیین مدیر جایگزین با ثبت دلیل و وضعیت پذیرش مسئولیت مشخص شود.

عمل	مرجع تصمیم پیشنهادی	شرط مهم
تأیید تشکیل	Owner/Admin پلتفرم	مجوز پلتفرمی؛ مدیر آموزشگاه کافی نیست.
پذیرش و حذف عضو	مدیر همان کلاس	عضویت و مجوز جاری؛ دلیل و ثبت سابقه
تولید و ارزیابی آموزش	مدرس یا مدیر دارای مجوز آموزشی	فقط پس از فعال‌شدن دامنه آموزشی
انتشار کانال	مدیر؛ مدرس با واگذاری صریح	نقش پیام‌رسان از مجوز کلاس مشتق شود.
خروج آخرین مدیر	انتقال معتبر یا بایگانی	کلاس فعال بی‌مسئول باقی نماند.

G07 همه حساب‌ها و نقش Student

InvitePersonalClassStudentCommand با وجود نام Student، ورودی destinationUserId دارد و در متن عملیات قید نقش مقصد توضیح داده نشده است. نام studentUserId در خروجی نیز محدودیت واقعی سرور را اثبات نمی‌کند. بنابراین ادعای «کاربر عادی قطعاً ممنوع است» از Swagger درست نیست .[E04]

قرارداد باید صریح بگوید حساب عادی و حساب دارای نقش Student می‌توانند عضو آموزشی شوند و هر حساب فعال مجاز به درخواست است. برای حساب عادی بدون آموزشگاه، Student، معلم، والد و مدیر سازمان، ماتریس آزمون صلاحیت لازم است. تشکیل یا عضویت نباید نقش سراسری یا عضویت Organization جدید بسازد.

استفاده مجدد: PlatformMeResult و کاتالوگ نقش‌های پلتفرم برای اختیار Owner/Admin موجودند .[E07] Workspace شخصی نیز در مدل فعلی وجود دارد .[E08] نیاز، روشن‌کردن دامنه اختیار و نقش کلاسی است.

عضویت دعوت و فهرست‌های کلاس

G03 پوشش فعلی و بخش‌های باقی‌مانده

کلاس شخصی ساخت دعوت، فهرست دعوت‌های دریافتی و پذیرش دعوت دارد. حذف participant نیز ثبت شده است. در همین دامنه، مسیر مشخص درخواست عضویت کاربر و بررسی آن، رد و لغو دعوت و قرارداد روشن خروج خود عضو دیده نشد. امکان ارائه بعضی رفتارها با عملیات مشترک باید با تیم Backend بررسی شود .[E02]

PersonalClassInvitationDto، expiresAtUtc و accepted دارد؛ enum وضعیت دعوت و دلیل پایان در آن تعریف نشده است. PersonalClassParticipantDto با active، دوره‌های خروج، حذف و تعلیق و نقش‌های هم‌زمان را تفکیک نمی‌کند. در مدل هدف، دعوت و درخواست از عضویت فعال جدا بمانند؛ حالت در انتظار، دسترسی خصوصی ایجاد نکند .[E04]

موضوع	تکمیل مورد نیاز
دعوت	Pending، Accepted، Declined، Revoked و Expired یا معادل روشن؛ انقضا و پذیرش آگاهانه
درخواست عضویت	ثبت و رسید؛ بررسی مدیر؛ تأیید یا رد؛ انصراف؛ جلوگیری از درخواست باز تکراری
عضویت	یک رابطه جاری برای حساب و کلاس؛ وضعیت و نقش محلی و تاریخچه دوره‌ها
دعوت و درخواست هم‌زمان	یک عضویت نهایی؛ بسته‌شدن درخواست یا دعوت باقی‌مانده با علت روشن
پایان عضویت	اثر روی دو فضای ارتباطی و فایل؛ آخرین مدیر؛ رفتار بازپیوستن

G14 فهرست و هویت قابل نمایش

GET /api/v1/personal-classes، GET /api/v1/personal-classes/invitations و GET /api/v1/personal-classes/{classId}/participants، آرایه خام برمی‌گردانند و پارامتر صفحه‌بندی ندارند. فیلتر وضعیت و ترتیب پایدار نیز در این عملیات ثبت نشده‌اند .[E17]

برای فهرست‌های قابل رشد، page یا cursor و limit و ترتیب مشخص تعریف شود. پاسخ اعضا، هویت امن قابل نمایش و نقش محلی لازم را فراهم کند تا کلاینت از نام studentUserId نقش را حدس نزند یا برای هر ردیف به اطلاعات خصوصی حساب نیاز پیدا نکند. الگوی صفحه‌بندی مدیریتی موجود در آموزشگاه قابل بررسی است.

دعوت و درخواست عضویت پیام‌رسان از قبل قرارداد دارند. بازاستفاده منطق آنها ارزشمند است؛ پذیرش مستقیم گروه نباید مسیر عضویت و ظرفیت کلاس را دور بزند [SB1]، .[E05]

اتصال گروه و کانال و دسترسی هماهنگ

G04 مرز سازمانی الگوی موجود

GET /api/v1/organization/classes/{classId}/official-spaces خروجی OfficialSpacesPairResult دارد؛ group و channel، وضعیت هر فضا، attemptCount و lastFailureCategory در مدل موجودند. اما organizationId در جفت فضا و metadata آن غیر nullable است و OfficialSourceKind فقط Organization و Class دارد .[E05]

این شاهد، پایه خوب برای ساخت دو فضاست؛ پوشش کلاس مستقل از آن نتیجه نمی‌شود. باید پیوند قابل دریافت از کلاس مستقل به هر دو conversationId و نوع مبدا معتبر تعریف شود. classId مستقل نباید با ساخت Organization یا شناسه سازمان ساختگی به قرارداد فعلی تحمیل شود. نام نوع مبدا می‌تواند توسعه یابد یا binding مشترک دقیق‌تری ارائه شود.

G05 تضمین‌های مخصوص کلاس مستقل

رویداد	رفتار هدف	شاهد لازم برای پذیرش
تأیید چندباره	یک کلاس و یک گروه و یک کانال	کنترل یکتایی و آزمون اجرای مجدد همان intent
شکست فقط کانال	حفظ گروه موجود و ادامه همان عملیات	وضعیت ناقص و شناسه‌های پایدار؛ تلاش مجدد بدون فضای تازه
حذف یا خروج عضو	لغو خواندن و نوشتن و دریافت تازه فایل در هر دو فضا	آزمون API، دانلود و اتصال زنده پس از لغو
تغییر مدیر یا مدرس	بازمحاسبه مجوز و حذف اختیار قدیمی	مجوز جاری کلاس منبع تصمیم باشد.
بایگانی یا تعلیق	توقف پذیرش و نوشتن هماهنگ	وضعیت مشترک و کنترل تمام مسیرهای تغییر

CreatePersonalClassCommand، clientOperationId دارد؛ پس نمی‌توان گفت هیچ سازوکار تکرار فرمانی وجود ندارد. آنچه هنوز مستند نشده، تضمین یک نتیجه مشترک در ایجاد کلاس و هر دو فضا و نحوه ادامه پس از خطاست .[E01]

عضویت کلاس باید مبنای اختیار گروه و کانال وابسته باشد. افزودن یا حذف مستقل در UI عمومی گروه، دعوت مستقیم فضای وابسته و انتقال مالکیت گفتگو باید با این مرجع سازگار شوند. بی‌صداکردن گفتگو از خروج کلاس جدا بماند. روش داخلی مانند Outbox یا کار ترمیم پیشنهاد فنی است؛ وجود یا نبود آن در کد بررسی نشده است.

اصل دانلود با مجوز جاری در توضیح API فایل موجود است .[E12] همین اصل برای عضویت و فایل کلاس مستقل باید با سناریوی اجرای واقعی اثبات شود.

احراز هویت خطا و نشانی محیط

G08 احراز هویت در قرارداد منتشرشده

ریشه OpenAPI فاقد security است؛ components/securitySchemes نیز تعریف نشده و هیچ‌یک از ۳۸۸ عملیات security صریح ندارند. در عین حال، VerifyOtpResult و RefreshSessionResult توکن‌های دسترسی و refresh را تعریف می‌کنند و بعضی توضیحات، نشست معتبر را الزامی می‌دانند [E14]، [E18].

scheme واقعی سرویس، برای مثال Bearer در صورت تطابق با پیاده‌سازی، معرفی شود. عملیات عمومی ورود از عملیات حساب و ادمین جدا علامت‌گذاری شوند و مجوزهای دامنه توضیح داده شوند. این اصلاح، مصرف Swagger و تولید کلاینت را قابل اتکاتر می‌کند؛ نتیجه فعلی به معنی اثبات نبود احراز هویت در Backend نیست.

G09 خطای قابل پردازش

۳۴۷ عملیات هیچ پاسخ غیر 2xx مستند ندارند. در نمونه‌های بعضی مسیرها، code و correlationId دیده می‌شود، اما ProblemDetails فقط type، title، status، detail و instance را تعریف می‌کند. extensionها ممکن است در اجرا وجود داشته باشند ولی قرارداد نوع‌دار مشترک ندارند [E16].

دسته خطا	قرارداد مورد نیاز
مجوز و زمینه	401 و 403 یا 404 طبق سیاست افشای وجود منبع؛ کد قابل ترجمه
داده نامعتبر	کد پایدار، خطاهای فیلد و قواعد شرطی؛ حفظ ورودی کلاینت
تعارض و ظرفیت	تفاوت نسخه کهنه، وضعیت ناسازگار و ظرفیت پر؛ شناسه نتیجه قبلی در بازپخش
نرخ و سرویس	429 و Retry-After در صورت کاربرد؛ سرویس ناآماده با علت امن و اقدام بعدی
ردگیری	correlationId یا traceId تعریف‌شده؛ عدم نمایش stack trace یا رازها

G15 نشانی امن مصرف توکن

نشانی ارائه‌شده و servers[0].url در فایل بررسی‌شده HTTP هستند و مستندات از همان HTTP دریافت شدند. اینکه این نشانی محیط توسعه است یا مسیر نهایی کاربران، مشخص نشده است. پیش از مصرف توکن واقعی در محیط عمومی، base URL رسمی HTTPS و نقش gateway یا reverse proxy روشن شود [SB1].

هیچ درخواست دارای توکن یا آزمون دسترسی به endpointهای ادمین انجام نشده است. دسترسی بدون ورود به خود مستندات، به‌تنهایی آسیب‌پذیری API محسوب نمی‌شود. مرجع قالب احراز هویت و پاسخ‌ها، OpenAPI 3.0.1 است [R1].

اعتبارسنجی و کیفیت توصیف عملیات

G10 حدود ورودی در Schema

در کل فایل، هیچ minLength، maxLength، minimum، maximum، minItems، maxItems یا pattern ثبت نشده است. type، format، enum و required موجودند، اما برای بیان همه قواعد محصول کافی نیستند. این مشاهده به معنای پذیرفته‌شدن ورودی نامعتبر در اجرای واقعی نیست .[E18]

نمونه واقعی	ابهام مستندات	اصلاح قابل پذیرش
CreatePersonalClassCommand فیلد title	required است ولی طول یا رشته خالی محدود نشده.	حداقل و حداکثر عنوان و شیوه نرمال‌سازی اعلام شود .[E01]
CreateClassCommand فیلد capacity	integer است ولی حداقل و حداکثر ندارد.	دامنه مجاز مطابق سرویس و پیام خطای مشخص ثبت شود .[E09]
CreateClassLessonCommand فیلد fileAssetIds	توضیح endpoint حداکثر ۱۰ فایل را می‌گوید؛ maxItems ندارد.	Schema و متن با هم همسان شوند .[E09]
POST /api/v1/files	بدنه الزامی است؛ File در required مدل فرم نیست.	الزام فایل، نوع و حجم و خطای نبود فایل صریح شوند .[E12]
pageSize و limit	بعضی فهرست‌ها مقدار پیش‌فرض دارند ولی حد دامنه ماشین‌خوان ندارند.	حدود و رفتار مقدار بیش از سقف ثبت شوند .[E17]

قواعدی مانند پایان پس از شروع، پذیرش فقط یک مقصد username یا phoneNumber و شرط آماده‌بودن فایل ممکن است نیاز به توضیح یا اعتبارسنجی تکمیلی داشته باشند. همه آنها الزاماً با یک keyword ساده بیان نمی‌شوند؛ حداقل خطا و مثال و قاعده شرطی باید معلوم باشد.

G11 عملیات قابل مصرف و ردیابی

operationId در هیچ عملیات ثبت نشده است؛ summary در ۵ و description در ۲۰ مورد دیده می‌شود. نبود operationId نقض الزامی استاندارد نیست، اما SDK و گزارش خطا و تطبیق صفحه با API را دشوارتر می‌کند. شناسه‌های پایدار و یکتا و توضیح نقش، زمینه و پیش‌شرط برای هر عملیات پیشنهاد می‌شود [E18، .[R1

نمونه خوب موجود، مسیرهای درس و دعوت والد است: مجوز، نسخه، علت خطا و رفتار اجرای مجدد را توضیح می‌دهند. همین قالب ابتدا برای PersonalClasses، Auth، ادمین و تغییرات پراثر گسترش یابد. مثال موفق و مثال خطای واقعی همراه با پاسخ نوع‌دار به مصرف‌کننده داده شود.

معیار پذیرش: کلاینت از روی Schema و شرح عملیات بتواند ورودی معتبر، علت رد و اقدام بعدی را بفهمد؛ نیازی به حدس از نام DTO یا خواندن کد سرور نداشته باشد.

تکرار فرمان نسخه و پاسخ‌های فاقد نوع

G12 الگوهای موجود و ناسازگاری‌ها

ایجاد کلاس شخصی و گفتگو clientOperationId دارند. مسیر درس، payload متفاوت با همان شناسه را 409 و نسخه کهنه را 412 توضیح می‌دهد. دستیار نیز X-AI-Operation-Id را تعریف کرده و صریح می‌گوید اگر operationId در بدنه باشد، باید یکسان باشند؛ حذف Header شناسه تازه می‌سازد [E01]، E09، .[E11

این الگوها باید حفظ شوند. در مقابل، CreateClassCommand شناسه فرمان ندارد و PersonalClassDto نسخه ندارد؛ بایگانی و حذف participant هم در قرارداد شخصی علت و کنترل نسخه مشخصی ندارند. سیاست مورد نیاز هر عمل و نتیجه تلاش مجدد باید مستند شود. برای عملیات طبیعیِ idempotent، افزودن اجباری UUID همیشه لازم نیست؛ اثر نهایی و پاسخ قابل بازیابی اهمیت دارد.

G13 پنج پاسخ موفق بدون Schema محتوا

عملیات واقعی	کمبود توصیف
GET /api/v1/sources/{id}/content	200 بدون قرارداد محتوای متن، JSON ساخت‌یافته، بایت یا شیوه آمادگی
GET /api/v1/conversations/{conversationId}/moderation/cases/{caseId}/evidence/files/{fileAssetId}	200 فاقد توصیف نوع بدنه دانلود
GET /api/admin/v1/moderation/cases/{caseId}/evidence/files/{fileAssetId}	200 فاقد توصیف نوع بدنه دانلود
DELETE /api/v1/personal-classes/{classId}/participants/{participantId}	200 بدون تعیین بدنه یا تأیید صریح پاسخ خالی
PUT /api/admin/v1/commerce/plans/{planId}/availability	200 بدون مدل نتیجه یا توصیف پاسخ خالی

برای هر مورد، یا Schema و Content-Type و Headerهای لازم مشخص شوند، یا پاسخ واقعاً خالی با status مناسب و رفتار روشن مستند شود. GET /api/v1/files/{fileId}/content از قبل نمونه مناسبی از پاسخ باینری، 206 و 416 دارد؛ هیچ نیازی به معرفی آن به‌عنوان API گمشده نیست [E12]، .[E18

معیار پذیرش: Retry پس از قطع پاسخ اثر مضاعف نسازد؛ تعارض نسخه قابل تشخیص باشد؛ ابزار تولید کلاینت برای هر پاسخ بداند چه چیزی را باید بخواند. این‌ها معیار اجرای آینده‌اند و در این بررسی اجرا نشده‌اند.

آموزش و منابع در کلاس مستقل

G16 تعمیم آموزش سازمانی

کلاس، جلسه، حضور، درس، تکلیف، آزمون، تلاش، تصحیح، انتشار نتیجه و اصلاحیه در دامنه academic وجود دارند. برای نمونه، ایجاد کلاس رسمی academicPeriodId و courseId می‌خواهد و توضیح مسیرهای درس، Workspace سازمانی و عضویت یا انتساب فعال همان کلاس را الزامی می‌داند .[E09]

این قراردادها پوشش آموزشگاه را نشان می‌دهند؛ استفاده مستقیم با شناسه PersonalClass بدون تعیین مجوز و نوع کلاس مجاز فرض نشود. PersonalClassDto دارای canCreateEducationalContent و educationalWorkflowStatus است، اما مقدار واقعی یا امکان آموزش مستقل با صرف وجود این فیلدها ثابت نمی‌شود .[E03]

اگر دامنه تصویب شد	تطبیق مورد نیاز
جلسه و درس	شناسه و نوع کلاس مستقل، مدیر یا مدرس مجاز، عضو عادی، انتشار و نسخه؛ بدون وابستگی اجباری به دوره سازمانی
تکلیف و آزمون	تلاش و مهلت سرور، مجوز عضو، فایل و رسید؛ استقلال از Enrollment سازمانی
نمره و گزارش	نتیجه خود عضو، بازخوردهای تفکیک‌شده، اصلاحیه و سیاست خروج؛ والد فقط با مجوز مصوب

G17 منبع و فایل و معنای Class

EducationalSourceScope شامل Personal، Class، Organization و Library است.
CreateEducationalSourceCommand و EducationalSourceResult دارای classId و فیلدهای scope هستند؛ مدل نتیجه نیز fileReady، sourceReady، aiReady و capabilityهای جدا دارد. بنابراین API منابع یا آمادگی پردازش غایب نیست .[E10]

ابهام این است که Class در این قرارداد دقیقاً کدام نوع کلاس را می‌پذیرد. اگر مستقل را پوشش می‌دهد، نمونه، مجوز و قاعده اتصال فایل آن ثبت شود. اگر فقط کلاس رسمی است، مرجع معتبر نوع کلاس یا scope دقیق‌تر پیشنهاد شود. الزام به افزودن enum تازه بدون بررسی resolver فعلی وجود ندارد.

فایلِ شخصی یا سازمانی صرفاً با داشتن UUID قابل انتقال به کلاس مستقل نیست. مالکیت، اجازه اشتراک در مقصد، دریافت پس از خروج و مصرف در AI باید روشن شود. الگوی مجوز جاری دانلود در قرارداد فایل موجود است و باید در دامنه مستقل هم رعایت شود .[E12]

این دو مورد P2 به فعال‌سازی دامنه آموزشی و منابع کلاسی مستقل وابسته‌اند؛ هسته تشکیل و اعضا و ارتباطات می‌تواند پیش از آنها تحویل شود.

دستیار و مدل تجاری فوق برنامه

G18 پوشش دستیار و توسعه پیشنهادی

۱۳ عملیات در Tag Ai وجود دارد: preflight منابع، چت، برنامه مطالعه، توضیح تکلیف، آمادگی آزمون و تحلیل‌های نقش‌محور. AiSourcePreflightResult شامل authorized، retrievalAvailable، commercialStatus و نسخه منابع است. این‌ها پایه مناسبی برای تفکیک مجوز، آمادگی و سهمیه هستند .[E11]

در این مجموعه، قرارداد روشن فهرست و بازیابی و حذف تاریخچه گفتگوهای AI و خروجی‌های نوع‌دار استودیو مانند خلاصه و فلش‌کارت و خودآزمایی دیده نشد. conversationId در چت به‌تنهایی یک جریان مدیریت تاریخچه نیست. ممکن است چت عمومی بخشی از تولیدها را پوشش دهد؛ پیش از افزودن مسیر، محصول و شکل ذخیره خروجی تعیین شود.

فعال‌بودن مدل، OCR و بازیابی و مصرف واقعی اعتبار از Swagger نتیجه نمی‌شود. GET /api/admin/v1/operations/health نیز aiIntegrationStatus دارد؛ این قرارداد برای دریافت شاهد آمادگی مفید است، اما در این کار فراخوانی نشده است .[E15]

G19 سهمیه و پرداخت‌کننده کلاس

CommerceContextType مقدار PersonalClass دارد و POST /api/v1/commerce/ai/simple-text/preflight، contextType و contextId می‌پذیرد. EntitlementKey نیز PersonalClassHosting دارد. پس نسبت‌دادن نبود کامل مفهوم تجاری کلاس شخصی به Backend دقیق نیست .[E13]

با این حال، SubscriptionOwnerType فقط Individual و Organization است؛ CreateOrderCommand شامل planVersionId، clientOperationId و هدف سفارش است و شناسه کلاس مستقلی ندارد. ممکن است هزینه میزبانی از اشتراک شخصی میزبان تأمین شود؛ یا مدل مجزایی لازم باشد. سیاست مالک قرارداد، پرداخت‌کننده و سهمیه مستقل پیش از تعیین API خرید نهایی شود.

موضوع	تعیین تکلیف لازم
منبع پرداخت	شخص مدیر، قرارداد کلاس یا حمایت آموزشگاه؛ بدون برداشت خودکار از اشتراک سازمان
سهمیه و Retry	intent ثابت و payer صریح؛ Headerهای AI موجود رعایت شوند.
تأیید پرداخت	Order و payment attempt و fulfillment از وضعیت معتبر سرویس؛ نه صرف callback یا نمایش UI
آموزش با AI	منابع مجاز و زمینه روشن؛ داده کلاس دیگر و یادداشت خصوصی به پاسخ وارد نشود.

API کاتالوگ، quote، سفارش و شروع پرداخت وجود دارد. callback در این فایل به‌عنوان قرارداد بررسی نشده و نبود آن در Swagger، نبود مسیر پرداخت داخلی یا ارائه‌دهنده را ثابت نمی‌کند.

رویداد ممیزی و حریم کلاس

G20 کاتالوگ رویدادهای فوق‌برنامه

دو مسیر realtime برای تغییرات حساب و Inbox وجود دارد. AccountChangePageResult دارای cursor، watermark، epoch و contextRevision است و RealtimeInvalidation دارای key، resourceId و payloadVersion است. پس زیرساخت دریافت تغییرات غایب نیست .[E15]

برای دامنه جدید، کلیدها و payload درخواست تشکیل، تصمیم، تغییر مدیر، عضویت، آماده‌شدن فضاها و بایگانی تعریف شوند. key در Schema رشته آزاد است؛ مصرف‌کننده از این فایل فهرست رویدادهای کلاس را نمی‌فهمد. می‌توان کاتالوگ نسخه‌دار مستند کرد؛ الزام به endpoint realtime موازی وجود ندارد.

دریافت تکراری یا بی‌ترتیب رویداد نباید مجوز حذف‌شده را بازگرداند. همگرایی نمای اعضا می‌تواند پس‌زمینه باشد، اما بررسی مجوز خواندن و دریافت فایل باید وضعیت معتبر جاری را رعایت کند. این رفتار نیازمند آزمون اجراست، نه استنتاج از وجود .cursor

G21 سابقه در محدوده کلاس

GET /api/admin/v1/audit-logs، فیلتر بازیگر، عمل، هدف و بازه زمانی دارد. AdminAuditLogItem نیز reason، correlationId، result و beforeSummary و afterSummary را تعریف می‌کند؛ پایه ممیزی از قبل وجود دارد .[E19]

قرارداد هدف مشخص کند کدام رویدادهای کلاس ثبت می‌شوند و مدیر یا عضو همان کلاس چه بخشی را می‌تواند ببیند. targetType و targetId می‌توانند برای کلاس به کار روند؛ ساخت سامانه ممیزی دوم ضرورت ندارد. یادداشت داخلی ناظر، اطلاعات خصوصی افراد و راز دعوت نباید در خروجی عمومی یا گزارش عضو افشا شوند.

G22 سن مسدودی و رابطه والد

CommunicationAge، MessagingPrivacy، MessagingSafety و دعوت و رابطه والد قرارداد دارند. پذیرش دعوت والد حتی رضایت صریح و ثبت اتمیک رابطه را در توضیح عملیات بیان می‌کند. بنابراین نبود کامل مدیریت سن یا والد به Backend نسبت داده نمی‌شود .[E20]

لازم است این قواعد با عضویت کلاس مستقل هماهنگ شوند: مسدودی دو همکلاسی، جستجوی حساب مقصد، دعوت کاربر کم‌سن، اجازه پیام خصوصی، نمایش اعضا و شماره، داده پس از خروج و حق والد. نقش Parent به‌تنهایی مجوز دیدن پیام یا نمره کلاس مستقل نیست؛ دامنه دسترسی والد هنوز تصمیم محصول می‌خواهد.

معیار پذیرش :P1 رویداد و تاریخچه برای زمینه درست قابل دریافت باشد؛ لغو مجوز مؤثر بماند؛ سیاست حریم پیش از عرضه به مخاطبان مربوط تصویب و در قرارداد قابل فهم شود. این سند حکم حقوقی یا گزارش تست نفوذ ارائه نمی‌کند.

طرح پیشنهادی تکمیل قرارداد هسته

نام مسیرهای جدول صرفاً پیشنهاد برای بحث تیمی است و در Swagger خوانده‌شده وجود ندارد. قبل از ایجاد namespace تازه، امکان نگاشت به PersonalClasses فعلی بررسی شود. قیدهای محصول و مرز دسترسی مهم‌تر از نام مسیر هستند.

عملیات پیشنهادی	ورودی کلیدی	نتیجه مورد انتظار
POST /api/v1/personal-class-requests	title، هدف، مخاطب، ظرفیت؛ clientOperationId	requestId، status، version و رسید
POST /api/v1/personal-class-requests/{id}/submit	نسخه و شرایط پذیرفته‌شده	ارسال همان درخواست؛ بدون تشکیل پیش از تأیید
POST /api/admin/v1/personal-class-requests/{id}/decisions	تصمیم، علت، مدیر نهایی و نسخه	تصمیم واحد؛ classId و وضعیت آماده‌سازی
GET /api/v1/personal-classes/{id}/spaces	کلاس مجاز	group و channel و state و قابلیت مؤثر
POST /api/v1/personal-classes/{id}/join-requests	حساب فعال و شرایط پذیرش	درخواست باز یا نتیجه موجود؛ بدون دسترسی زودهنگام
POST /api/v1/personal-classes/{id}/manager-transfers	نامزد، دلیل و نسخه	وضعیت پذیرش و انتقال معتبر مسئولیت

مدل‌های حداقلی پیشنهادی

ClassRequest: درخواست‌دهنده، نسخه، وضعیت، اطلاعات ارسال‌شده، مدیر پیشنهادی، مدرس اختیاری و تاریخچه تصمیم. ClassDetail: مدیر مسئول، نقش‌های مؤثر کاربر، status، capacity، version، وضعیت دو فضا و capabilities. ClassMembership: userId، membershipId، نقش‌ها، وضعیت و دوره عضویت؛ بدون الزام به Student سراسری.

Invitation و JoinRequest از عضویت فعال جدا باشند؛ هرکدام وضعیت و انقضا و تصمیم و علت مناسب داشته باشند. ClassSpaces می‌تواند از الگوی موجود جفت فضا الهام بگیرد، با مرجع کلاس مستقل و بدون organizationId اجباری. ردیابی آماده‌سازی باید شناسه پایدار و وضعیت قابل بازیابی بدهد.

قواعد داده و سازگاری

یک کلاس برای یک درخواست تأییدشده، یک فضای هر نوع برای هر کلاس و یک عضویت جاری برای هر حساب و کلاس تضمین شود. محل و روش قیدها بعد از بررسی مدل فعلی انتخاب شوند. ordinary و Student هر دو به همان هویت مرکزی متصل بمانند و عضویت آموزشگاه ساخته نشود.

پذیرش و رد و لغو دعوت، بررسی درخواست عضویت، تغییر نقش، پایان عضویت، بایگانی و تاریخچه نیز قرارداد لازم دارند؛ جدول نام‌گذاری نمونه است و فهرست کامل API هدف محسوب نمی‌شود.

برنامه اصلاح و انتشار

مرحله	کار و وابستگی	مسئول و دروازه خروج
۰ تثبیت مرجع	فایل OpenAPI نسخه‌دار؛ تطبیق policyها و DTOها با کد؛ تعیین مرز کلاس و تصمیم‌های باز	Backend و محصول؛ نگاشت هر G به تغییر مستند یا اجرا
۱ هسته قرارداد	G01، G02، G03 و G06؛ درخواست و تصمیم، نقش، عضویت، ظرفیت و وضعیت	Backend و محصول؛ قرارداد قابل بررسی و آزمون حساب‌های مختلف
۲ اتصال ارتباطات	G04 و G05؛ جفت فضای مستقل، همگام‌سازی، بازیابی و کنترل مسیرهای عمومی پیام‌رسان	Backend و تضمین کیفیت؛ عدم تکرار و عدم مجوز اضافی
۳ مصرف کلاینت	G07 تا G15؛ احراز هویت مستند، خطا، اعتبارسنجی، SDK و فهرست‌ها؛ G20 تا G22	Backend، Frontend و عملیات؛ آزمون قرارداد و حریم و اتصال
۴ قابلیت‌های مشروط	G16 تا G19 پس از تصویب آموزش، منابع، استودیو و مدل تجاری	محصول و تیم‌های دامنه؛ عدم فعال‌سازی نمایشی قابلیت ناآماده

هسته به‌صورت یک جریان قابل استفاده تحویل شود

مرحله‌های ۱ و ۲ تا تکمیل معیارهای مشترک، هسته عمومی آماده تلقی نشوند. تأیید کلاس بدون مسیر معتبر دو فضای وابسته و لغو دسترسی اعضا، نیاز قطعی محصول را کامل نمی‌کند. ایجاد حساب سازمانی برای دورزدن محدودیت‌ها راه‌حل قابل قبول نیست.

مهاجرت PersonalClasses و کلاینت فعلی

شناسه و میزبان و اعضا و دعوت‌ها و بایگانی موجود فهرست و نگاشت شوند. الزام به تأیید مجدد کلاس‌های قبلی تصمیم محصول است؛ داده موجود حذف نشود. برای تشکیل‌های تازه، مسیر POST فعلی نیز به چرخه تأیید نگاشت یا با خطای مشخص محدود شود. صرف مخفی‌کردن دکمه ایجاد در کلاینت کافی نیست.

اگر شکل پاسخ یا مفهوم نقش تغییر می‌کند، دوره سازگاری و نسخه مصرف‌کننده تعریف شود. endpoint موازی با دو مرجع حقیقت ایجاد نشود. ویژگی‌های تازه با پرچم قابلیت عرضه شوند و بازگشت نسخه، داده ساخته‌شده را حذف نکند. نسخه OpenAPI و یادداشت تغییر همراه انتشار به کلاینت تحویل شود.

زمان و هزینه اجرا از روی Swagger قابل برآورد دقیق نیست. این مراحل ترتیب وابستگی‌اند و به معنی انجام تغییر یا تأیید معماری داخلی موجود نیستند.

معیار پذیرش هسته فوق برنامه

موارد زیر سناریوی پذیرش پیشنهادی برای محیط آزمون کنترل‌شده‌اند و در این بررسی اجرا نشده‌اند.

کد	سناریو	نتیجه قابل پذیرش
V01	عادی بدون آموزشگاه، Student، معلم، والد و مدیر درخواست بدهند.	صلاحیت طبق حساب فعال؛ بدون تحمیل نقش یا عضویت سازمانی
V02	از UI و API فعلی ایجاد، تشکیل پیش از تأیید تلاش شود.	کلاس فعال یا فضای دارای محتوا پیش از تصمیم مجاز ایجاد نشود.
V03	تأیید با مدیر پیش‌فرض و مدیر جایگزین انجام شود.	درخواست‌دهنده پیش‌فرض؛ جایگزینی فقط با اختیار پلتفرم و سابقه روشن
V04	مدرس خالی یا مدیر هم‌زمان مدرس باشد.	نبود مدرس مانع هسته نشود؛ نقش آموزشی با مجوز صریح جمع شود.
V05	تأیید و پیام پردازش چند بار برسد.	یک کلاس و یک گروه و یک کانال؛ نتیجه ثابت قابل بازیابی
V06	گروه ساخته شود ولی ساخت کانال خطا بدهد.	وضعیت ناقص؛ ادامه همان عملیات بدون گروه تازه؛ فعال‌سازی کنترل‌شده
V07	دعوت و درخواست یک حساب هم‌زمان تأیید شوند.	یک عضویت نهایی؛ بسته‌شدن موارد باز دیگر؛ بدون دسترسی Pending
V08	دو نفر برای آخرین ظرفیت هم‌زمان پذیرفته شوند.	فقط یک پذیرش؛ ظرفیت مصوب نقض نشود.
V09	عضو متصل حذف یا از کلاس خارج شود.	خواندن و ارسال و دریافت تازه فایل در دو فضا غیرمجاز شود.
V10	مدیر منتقل یا آخرین مدیر قصد خروج کند.	مدیر قدیمی اختیار اضافی نداشته باشد؛ کلاس فعال بی‌مسئول باقی نماند.
V11	کلاس بایگانی شود یا لینک قدیمی آن باز شود.	نوشتن و پذیرش بسته؛ سوابق مجاز حفظ؛ عضو حذف‌شده دوباره مجاز نشود.
V12	عضویت آموزشگاه تغییر کند یا classId دیگری ارسال شود.	استقلال کلاس حفظ؛ شناسه به‌تنهایی مجوز ندهد؛ داده فضای دیگر افشا نشود.

برای بستن G05 و بخش‌های امنیتی، صرف نمایش پاسخ 200 کافی نیست. اثر نهایی در کلاس، گروه، کانال، فایل و اتصال زنده باید مشاهده شود؛ در صورت جدابودن سرویس‌ها، خطا و بازپخش نیز پوشش داده شوند.

پذیرش قرارداد و شواهد اجرای لازم

کد	کنترل پیشنهادی	شاهد خروج
C01	security و scheme واقعی با سیاست عمومی و خصوصی همسان شوند.	کلاینت تولیدشده روش احراز هویت را بداند؛ آزمون مجوز حساب و ادمین
C02	تمام عملیات operationId یکتا و شرح نقش و زمینه داشته باشند.	فایل نسخه‌دار و نگاشت صفحه و عملیات؛ کنترل خودکار تکرار شناسه
C03	خطاهای فیلد، مجوز، تعارض، نرخ و آمادگی نوع‌دار شوند.	Schema و مثال مطابق پاسخ واقعی؛ code و correlationId قابل پردازش
C04	حدود ورودی و File الزامی و قواعد زمان همسان شوند.	آزمون مقادیر مرزی، فرم خالی و تعداد پیوست؛ پیام قابل اقدام
C05	پنج پاسخ بی‌نوع و فهرست‌های خام تعیین تکلیف شوند.	تولید کلاینت بدون حدس درباره محتوا؛ صفحه‌بندی قابل استفاده
C06	سیاست intent و نسخه و پاسخ نامعلوم روشن شود.	بازپخش با همان payload؛ تعارض payload؛ حفظ نتیجه و عدم اثر مضاعف
C07	نشانی محیط و HTTPS و پیکربندی AI مشخص شوند.	مرجع محیط مقصد و نتیجه readiness؛ قرارداد موجود با فعال‌بودن اشتباه نشود.
C08	حریم، سن، مسدودی و ممیزی با کلاس مستقل سازگار شوند.	آزمون نقش‌ها و داده مجاز؛ سابقه قابل ردیابی و عدم افشای رازها

آنچه برای نتیجه‌گیری درباره اجرا لازم است

بررسی policy و authorization handler و قرارداد سرویس؛ محیط آزمون با داده مجاز؛ حساب‌های عادی، Student، مدیر کلاس، مدرس، مدیر آموزشگاه، Admin و Owner؛ امکان مشاهده نتیجه آماده‌سازی و لاگ مجاز. برای تراکنش و تکرارپذیری، آزمون هم‌زمانی و شکست میانی لازم است. برای فایل و AI، پیکربندی و وضعیت واقعی سرویس باید مشخص باشد.

تصمیم‌هایی که محصول باید ببندد

دامنه آموزش مستقل؛ تعداد مدیران و مدرسان؛ قواعد انتقال مدیر پس از تشکیل؛ کشف عمومی کلاس؛ صلاحیت حساب کم‌سن و دسترسی والد؛ شمارش ظرفیت؛ بازپیوستن حذف‌شده و خروج مستقل از گروه؛ نگهداری سوابق؛ پرداخت‌کننده و سهمیه کلاس. پیشنهاد API بدون این تصمیم‌ها ممکن است دوباره‌کاری بسازد.

هیچ‌یک از نتایج V یا C در این گزارش علامت قبولی اجرای فعلی ندارند. این جدول، فهرست شاهد لازم برای تبدیل شکاف قرارداد یا ابهام به نتیجه تأییدشده است.

شواهد قرارداد کلاس و آموزش

همه ارجاع‌ها به فایل SB1 با همان نام مسیر و Schema اشاره می‌کنند. ریشه مسیرها همان سرور معرفی‌شده در Swagger است؛ E شناسه تحلیلی این گزارش است و operationId موجود در سرویس نیست.

کد	عملیات یا محل دقیق	داده مشاهده‌شده
E01	POST /api/v1/personal-classes CreatePersonalClassCommand	title و clientOperationId؛ خروجی PersonalClassDto؛ بدون شرح چرخه بررسی
E02	Tag PersonalClasses در paths	۹ عملیات؛ ایجاد، سه فهرست، جزئیات، بایگانی، دعوت و پذیرش و حذف participant؛ چرخه درخواست تشکیل ثبت نشده.
E03	GET /api/v1/personal-classes/{classId} PersonalClassDto	hostUserId، archived، isHost، canCreateEducationalContent، educationalWorkflowStatus؛ بدون version و capacity
E04	PersonalClassInvitationDto PersonalClassParticipantDto	دعوت: expiresAtUtc و accepted؛ عضو: studentUserId، active و joinedAtUtc
E05	GET /api/v1/organization/classes/{classId}/official-spaces OfficialSpacesPairResult و OfficialSourceKind	group و channel؛ organizationId غیر nullable؛ مبدا Organization یا Class؛ وضعیت و تلاش هر فضا
E06	POST /api/admin/v1/provisioning ProvisionOrganizationCommand	organizationName و initialManagerUserId؛ قرارداد ساخت سازمان
E07	GET /api/admin/v1/me GET /api/admin/v1/roles	PlatformMeResult و PlatformRoleCatalogItem با نقش و permissions
E08	GET /api/v1/workspaces/snapshot WorkspaceType و AccessContext	Personal و Organization؛ اطلاعات زمینه و عضویت و نقش سازمانی
E09	POST /api/v1/academic/classes POST /api/v1/academic/classes/{classId}/lessons	CreateClassCommand با دوره و درس و ظرفیت؛ توضیح درس با الزام Workspace سازمانی
E10	POST /api/v1/sources CreateEducationalSourceCommand و EducationalSourceResult	scope و classId؛ آمادگی فایل و منبع و AI؛ capabilityهای جدا

برای یافتن مدل در JSON از مسیر /components/schemas/#نام‌مدل استفاده شود. مرجع دقیق روش و path برای هر ادعا ذکر شده است؛ نبود توضیح یا عملیات با جستجوی کل snapshot بررسی شده است.

شواهد قراردادهای مشترک

کد	عملیات یا محل دقیق	داده مشاهده‌شده
E11	POST /api/v1/ai/chat POST /api/v1/ai/sources/preflight	SendAiChatCommand، AiChatResult و AiSourcePreflightResult؛ Headerهای X-AI-Operation-Id و X-AI-Payer با توضیح
E12	POST /api/v1/files GET /api/v1/files/{fileId}/content	فرم File؛ FileAssetResult؛ پاسخ باینری و Range و بررسی مجوز جاری
E13	POST /api/v1/commerce/ai/simple-text/preflight AiQuotaPreflightCommand و CommerceContextType	PersonalClass و contextId در preflight؛ مالک اشتراک Individual یا Organization
E14	POST /api/v1/auth/otp/verify POST /api/v1/auth/refresh ریشه security و components/securitySchemes	توکن دسترسی و refresh در نتیجه؛ metadata احراز هویت در OpenAPI تعریف نشده.
E15	GET /api/v1/realtime/account-inbox/changes GET /api/v1/realtime/changes GET /api/admin/v1/operations/health	AccountChangePageResult، RealtimeInvalidation و aiIntegrationStatus؛ زیرساخت تغییر و آمادگی موجود
E16	#/components/schemas/ProblemDetails GET /api/v1/academic/periods responses/400	مدل خطای پایه فاقد code و correlationId صریح؛ مثال همان پاسخ این دو فیلد را دارد.
E17	GET /api/v1/personal-classes GET /api/v1/personal-classes/invitations GET /api/v1/personal-classes/{classId}/participants	آرایه خام و بدون پارامتر صفحه‌بندی؛ مقایسه با page و pageSize فهرست‌های آموزشگاه
E18	کل paths و components در SB1	شمارش عملیات و توضیح و محدودیت و پاسخ؛ پنج پاسخ موفق بی‌Schema در صفحه ۱۴ فهرست شده‌اند.
E19	GET /api/admin/v1/audit-logs #/components/schemas/AdminAuditLogItem	بازیگر، هدف، علت، زمان، correlationId و خلاصه قبل و بعد؛ فیلترهای پرس‌وجو
E20	GET /api/v1/me/messaging-status PUT /api/v1/messaging/privacy POST /api/v1/invitations/{invitationId}/accept	قابلیت ارتباط و حریم؛ شرح رضایت والد و ثبت رابطه؛ APIهای مسدودی و سن نیز در SB1 موجودند.

نام‌های جدیدی مانند PersonalClassRequest در پیشنهادهای صفحه ۱۸، Schema موجود SB1 نیستند. همین تفکیک باید در برآورد و برنامه تیم رعایت شود.

منابع و تصمیم تحویل به تیم

مرجع قرارداد بررسی‌شده

SB1 فایل OpenAPI معرفی‌شده از تنظیمات Swagger UI؛ عنوان MakanApp.Api | v1، نسخه 1.0.0 و قالب OpenAPI 3.0.1. دریافت مستندات با GET انجام شد. زمان پاسخ ثبت‌شده سرویس برای فایل، ۲ نوامبر ۲۰۲۶ ساعت ۱۳:۰۲:۳۱ UTC، معادل ساعت ۱۶:۳۲:۳۱ تهران است.

رابط مستندات: رابط Swagger بررسی‌شده

فایل قرارداد: فایل قرارداد OpenAPI

اثر انگشت SHA-256 نسخه خوانده‌شده:

9254141317a42d559223359d1060e8701c661624b7951ddb9114c842a0585371

مرجع نیاز محصول

PD1 سند محصول و معماری تجربه کاربری ماکان‌اپ نسخه ۱٫۰، ۴۰ صفحه، تهیه‌شده در همین گفت‌وگو بر پایه اطلس ۳۸۷ صفحه‌ای و تصمیم‌های کاربر. تصمیم‌های D01 تا D11، معیار تطبیق هسته مستقل‌اند؛ جلسه، درس، تکلیف، آزمون و گزارش برای مستقل، پیشنهاد محصول باقی مانده‌اند.

مرجع قالب مستندات

R1 مشخصات رسمی OpenAPI 3.0.1: مشخصات رسمی OpenAPI 3.0.1 . برای تفسیر security، Schema، required، nullable، Responses و operationId استفاده شده است. پیشنهادهای کیفیت این گزارش همگی الزام شکلی استاندارد نیستند.

صورت کار قابل واگذاری

Backend برای هر G مشخص کند: تغییر مستندات کافی است، تغییر قرارداد یا منطق لازم است، یا شاهد اجرای موجود باید ارائه شود. محصول چهار مورد P2 و سیاست‌های باز را تعیین تکلیف کند. Frontend صفحات را به operationId و خطا و capability وصل کند. تضمین کیفیت موارد V و C را در محیط آزمون اجرا و نتیجه را به همان شناسه G پیوند بدهد.

اولویت تحویل، هسته درخواست و نقش و عضویت و اتصال دو فضاست؛ هم‌زمان قراردادهای مشترک اصلاح شوند. آموزش کامل و استودیو و مدل تجاری مستقل بعد از تصویب دامنه وارد تعهد شوند.

این گزارش بر پایه snapshot مستندات است؛ ممیزی کد، آزمون Backend، آزمون نفوذ، بررسی تراکنش پایگاه داده یا استقرار انجام نشده است. تغییر بعدی Swagger باید با نسخه یا اثر انگشت تازه دوباره تطبیق داده شود.